

INTERNAL DOCUMENTATION • V1.0

Invoices Archive API

Internal Team Usage Guide — query a day's invoices safely without a database shell.

System: Carolina Furniture Concepts — backend (Node.js / Express / MySQL)

Module: /api/invoices-archive (read-only)

Owner: CFC Backend Engineering

Issued: May 19, 2026 • **Audience:** Internal teammates (admin / manager)

This document and the API it describes are CFC-internal. Do not share externally.

Table of Contents

- | | |
|--|--------------------------------------|
| 1. API Overview | 11. Error Responses & Status Codes |
| 2. Purpose & Use Cases | 12. Postman Setup Guide |
| 3. Security & Access Restrictions | 13. Pagination |
| 4. Why Direct DB Access Is Not Allowed | 14. Rate Limiting & Abuse Prevention |
| 5. Authentication | 15. Important Notes for Teammates |
| 6. Base URL & Environments | 16. Troubleshooting |
| 7. Endpoint Reference | 17. Frequently Asked Questions |
| 8. Query Parameters | 18. Data Privacy Guidelines |
| 9. Sample Requests (curl) | 19. Internal Usage Disclaimer |
| 10. Sample Responses | 20. Changelog & Contact |

1. API Overview

The **Invoices Archive API** is an internal, read-only HTTP interface that exposes the contents of the `invoices_archive` table in the `cfc_form` database. It allows authorised teammates (administrators and store managers) to count and list invoices created on a given business day without requiring direct database access, a VPN session, or engineering assistance.

At a glance

- **Two endpoints:** list and count, both scoped to a single day.
- **Read-only by construction:** no INSERT / UPDATE / DELETE path is reachable.
- **Internal only:** protected by the existing CFC role-based middleware.
- **Time-zone safe:** "today" anchors to America/New_York (store-business day).

2. Purpose & Use Cases

- A manager asks: *"How many tickets did Arden write today?"* — call the count endpoint.
- An admin needs to audit a specific day's slugs, invoice types, and Birdeye send status — call the list endpoint.
- Support needs to locate a particular customer's ticket without engineering — list a day, filter by invoice type, then look up by slug.
- Finance needs to reconcile daily ticket volume against the POS report — call the count endpoint per day.

3. Security & Access Restrictions

The API is mounted behind the existing `requireRole(['admin', 'manager'])` middleware. Every request is authenticated by re-reading the caller's role from `cfc_users` on the server side. The client cannot bypass this by forging an `x-user-role` header — that header is ignored entirely. Employees (role = `employee`) receive HTTP 403.

4. Why Direct DB Access Is Not Allowed

- **Blast radius:** a shared DB credential lets any holder run UPDATE/DELETE. A read API cannot.
- **Audit trail:** every API call is logged with caller identity, date scope, and result size; raw SQL sessions are not.
- **Schema isolation:** teammates do not need to know that `form_json` is LONGTEXT, that timestamps are NY-local, or that pagination is required to avoid response bloat.
- **Cross-region safety:** production runs in the USA. Opening DB credentials to India-based teammates expands the attack surface; an internal HTTPS API does not.
- **Versionable contract:** the API can evolve; raw DB shape is a fragile contract.

5. Authentication

The CFC backend follows a header-or-body identity convention. The caller's user ID may be supplied in any one of:

- The HTTP header `X-User-Id: <numeric id>` — recommended for service-to-service calls.
- The query string `userId=<numeric id>` — convenient for quick browser checks.
- The JSON body field `userId` — for POST/PUT contracts (not applicable here; this API is GET-only).

The middleware then looks up the user in `cfc_users`, verifies `is_active=1`, and enforces role membership in `['admin', 'manager']`. A missing or invalid identifier returns **HTTP 401**. An identifier that resolves to an employee returns **HTTP 403**.

Note on x-api-key

This API does **not** introduce a separate `x-api-key` mechanism. CFC's existing role-based identity model is reused so that audit logs, role changes, and account deactivations apply uniformly. If a future external integration needs an API key, it will be added at the gateway layer, not retrofitted onto this endpoint.

6. Base URL & Environments

Environment	Base URL	Notes
Production	<code>https://api.123cfc.com</code>	Live store data — handle with care.
Local dev	<code>http://localhost:3000</code>	Requires <code>npm start</code> in <code>backend/</code> .

All endpoint paths in this document are relative to the base URL.

7. Endpoint Reference

7.1 List invoices for a day

GET `/api/invoices-archive?date=YYYY-MM-DD`

Returns a paginated list of `invoices_archive` rows whose `created_at` falls within the requested business day (America/New_York). Each row includes the parsed `form_json` by default; supply `includeFormJson=false` to omit it.

7.2 Count invoices for a day

GET `/api/invoices-archive/count?date=YYYY-MM-DD`

Returns the total number of invoices created on the requested business day. This endpoint is intentionally lightweight — it never reads `form_json`.

8. Query Parameters

Parameter	Required	Default	Type / Range	Description
<code>date</code>	No	NY business "today"	YYYY-MM-DD	Calendar-validated; rejects <code>2026-02-30</code> .
<code>limit</code>	No	50	1 – 200	Page size. Out-of-range values are clamped.
<code>offset</code>	No	0	≥ 0	Skip count for pagination.
<code>invoice_type</code>	No	—	A–Z / 0–9, up to 10 chars	Filter (e.g., RG, PH, QS, RTS). Case-insensitive.
<code>includeFormJson</code>	No	true	boolean	Set <code>false</code> to drop the LONGTEXT payload.
<code>userId</code>	Yes*	—	numeric	* required unless <code>X-User-Id</code> header is supplied.

9. Sample Requests (curl)

9.1 Count today's invoices

```
curl "https://api.123cfc.com/api/invoices-archive/count" \  
-H "X-User-Id: 17"
```

9.2 Count for a specific date

```
curl "https://api.123cfc.com/api/invoices-archive/count?date=2026-05-15" \  
-H "X-User-Id: 17"
```

9.3 List a day's invoices (default page)

```
curl "https://api.123cfc.com/api/invoices-archive?date=2026-05-15" \  
-H "X-User-Id: 17"
```

9.4 List without the heavy form_json payload

```
curl "https://api.123cfc.com/api/invoices-archive?date=2026-05-15&includeFormJson=false&limit=200" \  
-H "X-User-Id: 17"
```

9.5 Filter by invoice type (RG = regular sale)

```
curl "https://api.123cfc.com/api/invoices-archive?date=2026-05-15&invoice_type=RG" \  
-H "X-User-Id: 17"
```

9.6 Paginate page 2

```
curl "https://api.123cfc.com/api/invoices-archive?date=2026-05-15&limit=50&offset=50" \  
-H "X-User-Id: 17"
```

9.7 Identity via query string instead of header

```
curl "https://api.123cfc.com/api/invoices-archive/count?date=2026-05-15&userId=17"
```

10. Sample Responses

10.1 Successful count response

```
{  
  "success": true,  
  "ok": true,  
  "date": "2026-05-15",  
  "count": 47  
}
```

10.2 Successful list response (truncated)

```
{
  "success": true,
  "ok": true,
  "date": "2026-05-15",
  "count": 2,
  "total": 47,
  "limit": 50,
  "offset": 0,
  "data": [
    {
      "id": 48213,
      "slug": "RG-0515-AR-00012",
      "invoice_type": "RG",
      "transaction_mode": "SALE",
      "editable": 1,
      "birdeye_sent": 1,
      "form_json": { "billTo": { "name1": "Jane D." }, "subtotal": 1299.00 },
      "created_at": "2026-05-15T14:23:11.000Z",
      "updated_at": "2026-05-15T14:23:11.000Z"
    },
    {
      "id": 48214,
      "slug": "PH-0515-WV-00003",
      "invoice_type": "PH",
      "transaction_mode": "SALE",
      "editable": 0,
      "birdeye_sent": 0,
      "form_json": { "billTo": { "name1": "John K." }, "subtotal": 349.00 },
      "created_at": "2026-05-15T14:31:02.000Z",
      "updated_at": "2026-05-15T14:31:02.000Z"
    }
  ]
}
```

11. Error Responses & Status Codes

Scenario	HTTP	Body
No userId supplied	401	<code>{ "ok": false, "message": "Authentication required" }</code>
User inactive / deleted	401	<code>{ "ok": false, "message": "User not found or inactive" }</code>
Role is <code>employee</code>	403	<code>{ "ok": false, "message": "Forbidden" }</code>
Date malformed	400	<code>{ "code": "INVALID_DATE", "message": "Invalid date format. Expected YYYY-MM-DD." }</code>
Date impossible (e.g. Feb 30)	400	<code>{ "code": "INVALID_DATE", "message": "Invalid calendar date." }</code>
invoice_type fails regex	400	<code>{ "code": "INVALID_INVOICE_TYPE", "message": "Invalid invoice_type filter." }</code>
Unexpected server error	500	<code>{ "ok": false, "message": "Internal server error" }</code>

12. Postman Setup Guide

1. Open Postman and create a new **Collection** called `CFC – Invoices Archive`.
2. Add a **Collection variable** `baseUri` with the value `https://api.123cfc.com`.
3. Add a **Collection header** `X-User-Id: 17` (replace 17 with your own user id; visible in the CFC admin panel).
4. Create two requests:
 - `GET {{baseUri}}/api/invoices-archive?date=2026-05-15`
 - `GET {{baseUri}}/api/invoices-archive/count?date=2026-05-15`
5. Click **Send**. Verify a 200 response with `success: true`.
6. Save the collection to share with other teammates (without your personal user id baked in).

13. Pagination

The list endpoint uses simple `limit / offset` pagination:

- **limit** — clamped to `[1, 200]`. Default is 50.
- **offset** — non-negative integer. Default is 0.
- **total** — the response includes the unpaginated total for the day so the UI can render a page count.

For very large days, prefer `includeFormJson=false` when scanning — the response stays under a few hundred KB.

14. Rate Limiting & Abuse Prevention

There is currently no dedicated per-route rate limit on this endpoint; the wider CFC backend deployment relies on its upstream reverse proxy for ingress shaping. Internal callers should still observe the following guidelines:

- Do not poll either endpoint more than once every 10 seconds for the same date — both queries hit MySQL.
- Prefer the count endpoint for dashboards; the list endpoint for ad-hoc audit.
- For automated jobs, cache responses per `(date, invoice_type)` at the caller for at least 60 seconds.

15. Important Notes for Teammates

- **"Today" is always NY time.** If you live in India and want yesterday's IST data, pass an explicit `date`.
- **Do not log full `form_json`** to chat or shared docs — it contains customer PII.
- **Do not screen-share** Postman with response bodies expanded; redact PII fields first.
- **Bookmark this PDF** instead of memorising query strings.
- If an endpoint returns **403**, ask an admin to grant you the manager role in `cfc_users` — do not request your password to be re-issued.

16. Troubleshooting

Symptom	Likely Cause	Resolution
401 Authentication required	No <code>userId</code> header / param	Add <code>X-User-Id</code> or <code>?userId=</code> .
403 Forbidden	Role = employee	Ask CFC admin to escalate role.
400 INVALID_DATE	Wrong format or impossible date	Use <code>YYYY-MM-DD</code> , e.g. <code>2026-05-15</code> .
Count differs from dashboard	Time-zone confusion	Dashboard uses NY day; verify your local clock.
Empty <code>data</code> array	No invoices for that day	Confirm date; the API never 404s for empty days.
Response very large	<code>form_json</code> included	Add <code>&includeFormJson=false</code> .
500 Internal server error	DB pool exhaustion / transient	Retry; if persistent, ping <code>#cfc-backend</code> .

17. Frequently Asked Questions

Q. Can I write a script that hits this endpoint every minute?

Please do not. Cache the response for at least 60 seconds at the caller. The endpoints are intended for human audit and dashboard refresh, not high-frequency polling.

Q. The response gives me `created_at` in UTC. How do I convert?

MySQL stores datetimes as wall-clock values; what you see is the NY local time encoded as an ISO string. Treat it as NY time.

Q. Why are there `success` AND `ok` keys?

CFC's older endpoints emit `ok`. This endpoint emits both so the new contract works for new consumers without breaking existing tooling.

Q. Can I filter by customer name?

Not via this API. Use the existing search endpoint `/api/customers/search`. This endpoint is by-day audit, not search.

Q. Is data exposed via this endpoint covered by our PII policy?

Yes. Treat `form_json` contents as customer PII — name, phone, address. Do not paste it into Slack, email, or external trackers.

Q. Can I delete an invoice through this API?

No. The API exposes only `GET` handlers; no write path exists at any layer.

18. Data Privacy Guidelines

- Treat `form_json` as PII. It contains customer name, phone, and address.
- Do not export responses to personal devices, personal email, or third-party tools.
- Do not screenshot un-redacted responses for sharing.
- If you need to attach a sample to a ticket, redact PII first.
- Access is logged. Misuse will surface in the audit log review.

19. Internal Usage Disclaimer

This API is provided solely for internal Carolina Furniture Concepts operational use. It is not a public product. Distribution of credentials, screenshots of full responses, or use of this data for non-CFC purposes is prohibited and may constitute a breach of company policy and applicable data-protection law.

20. Changelog & Contact

Version	Date	Change
1.0	2026-05-19	Initial release: list + count endpoints, role-guarded, NY-anchored, btree index on <code>created_at</code> .

Owner: CFC Backend Engineering • **Contact:** internal Slack channel `#cfc-backend`